



Enterprise Risk Management

WHAT DOES IT REALLY MEAN TO MANAGE RISK
EFFECTIVELY ACROSS THE ENTERPRISE?



Contents

1. WHAT IS ENTERPRISE RISK MANAGEMENT (ERM)?



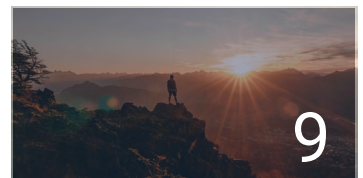
2. WHAT PROBLEMS DOES ERM SOLVE?



3. HOW DOES ERM SOLVE THESE PROBLEMS?



4. THE ERM ECOSYSTEM - HOW DOES IT ALL FIT TOGETHER?



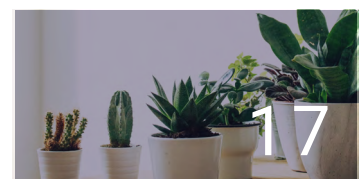
5. THE KEY ELEMENTS OF AN ERM FRAMEWORK



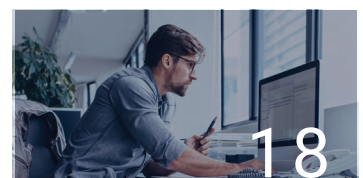
6. THE KEY ELEMENTS OF ERM PROCESSES AND SYSTEMS



7. BUILDING AN ERM FRAMEWORK THAT CAN GROW



8. THE OUTPUTS, USES AND VALUE PROPOSITION OF ERM



9. YOUR NEXT STEPS - MAKING IT HAPPEN



Introduction

Risk has been with us since the beginning of time. Driven primarily by our innate instinct for survival, human beings naturally recognize risk and manage it. As a result, our personal risk management capabilities are well developed and embedded within everything we do, often at the sub conscious level – we don't have to actively think about it.

Then, in the late 1700s, the industrial revolution came, and we built enterprises and worked collectively using all manner of complex processes and machines. As a result, the risks changed and they were no longer able to be managed by the individual. The many disasters that scatter the industrial revolution bear testament to this.

The changing of risk from a personal to an enterprise level primarily led to risk being managed in a siloed manner. Different approaches developed for different types of risk. Risk was managed in each area of the enterprise, separate from the others. Different approaches and frameworks, different terminology, duplication of processes and even different regulatory requirements by risk type developed.

This approach continued well into the 20th and 21st centuries and still unfortunately underlies many risk management frameworks today.

This ebook provides a comprehensive view of what true Enterprise Risk Management is and illustrates how it addresses the inherent problems in the traditional, siloed, non-enterprise approach. In this ebook, we'll cover the following topics:

1. What is Enterprise Risk Management (ERM)?
2. What problems does ERM solve?
3. How does ERM solve these problems?
4. The ERM ecosystem – How does it all fit together?
5. The key elements of an ERM framework
6. The key elements of ERM Processes and Systems
7. Building an ERM framework that can grow
8. The outputs, uses and value proposition of ERM
9. Your next steps – making it happen



1. What is Enterprise Risk Management (ERM)?

The Protecht Group was founded in 1999. Back then, we talked about “Risk Management”. We soon saw “Enterprise Wide Risk management” creeping into discussions, which became Enterprise Risk Management or “ERM”. As a firm, we adopted “ERM” as it exactly captured our focus - enabling customers to manage all of their risks on an enterprise basis, rather than using the traditional siloed approach. Our risk system, which commenced development in 2001, is proudly known as Protecht. ERM. From day 1 until now, it has been continuously developed with the principles of “ERM” at its core.

Over this time, we have seen many labels for risk management come and go, for what should essentially be the same thing. The two main alternative labels are:

- GRC – Governance, Risk and Compliance
- IRM – Integrated Risk Management

How do these labels compare with ERM? First, let’s look at GRC. Governance is a key component of any ERM framework and is already covered within ERM. Compliance Management and Compliance Risk Management are also key elements of an enterprise approach to risk and hence, GRC is simply a different label.

Now, let’s consider IRM. The essence of an ERM approach, as will be covered later, is the ability to collate, analyse and view risk at an enterprise level. This requires all of the elements of risk management, such as incident reporting, controls assurance and issues, to be integrated. We see “integration” as simply a key feature of ERM, not an alternative.

Finally, a note on Controls Testing (be it SOX, NIST, ISO, etc). Controls testing is a key component of ERM, but it is not the whole of ERM.

As a result, ERM is Protecht’s preferred label for what we do. That said, labels mean nothing. It is what underlies the label that matters. How does ERM solve the problems of traditional risk management?



2. What problems does ERM solve?

Traditional risk management has developed from bottom up and in a risk and business specific way. This means that certain risks in certain business areas are managed relatively well. This approach has been supported by frameworks, standards and even legislation focused on one specific risk type, whether it be Environmental, Health and Safety or Technology risk.

The key characteristics of this approach are:

- risks are managed in silos - risk silos and business silos.
- risk information and risk reports are separately produced by each silo.
- risk is analysed and managed on a micro, rather than macro, basis.
- risk is managed by a select group of “risk specialists”.

This approach has created many problems and inefficiencies, including:

- Inconsistency in
 - » the effort invested in managing risk across the enterprise. Some risks, such as safety, may be managed and invested in well, while others, such as fraud maybe under-invested.
 - » the way risks are described.
 - » the terminology, definitions and acronyms used across different risk types and different areas of the business.
 - » the way that risks are reported.
 - » the understanding of risk due to the high level of variation and resulting confusion across the range of enterprise risks.
- An inability to
 - » aggregate risks across the business and as a result, inability to provide a consolidated, aggregated and consistent risk view to the Board, Risk Committee and Executive Management.

- » compare and contrast different risks from different areas of the business.
- » carry out data analytics to identify trends, systemic issues and other insights that requires an enterprise view of risk.
- » engage the wider workforce.
- Cost and time inefficiency due to
 - » processes repeated across the enterprise with many variations.
 - » multiple systems and processes managing a range of different risk types.
 - » cumbersome reporting based on different reports coming from different systems. We have seen many instances of reports from multiple systems being consolidated in a master excel spreadsheet with pivot tables and the like - a very inefficient process. In addition, this leads to reporting being delivered late resulting in a more backward looking view of risk.





3. How does ERM solve these problems?

“Risk is Risk is Risk”

All risk is, in principle, the same. Risk is the effect of uncertainty on objectives¹. All risk is the same under this definition, and this is at the core of ERM. We should view, analyse, and manage all risks in a consistent way, while recognizing any nuances for specific risk types.

Based on this fundamental premise, ERM can solve the “traditional risk management” problems noted earlier in the following ways:

- **ERM uses one view of risk** - describing, analysing and managing all risks and related controls in a similar, consistent manner. For example, Risk Bow Tie Analysis is a great way to ensure a consistent approach to analysing risks across the business.
- **ERM is integrated via risk libraries or taxonomies** - once the risks are described and analysed in a consistent way, central libraries / taxonomies are developed for the different parts of risk (Cause, Event, Impact and Control libraries / taxonomies). Each risk is then catalogued by linking to the appropriate library / taxonomy. This is the start of “integration” that is central to ERM. This allows central cataloguing of risk and the ability to:
 - » aggregate all risks across the business according to the chosen common dimension.
 - » report all risks in a consolidated, consistent manner.
 - » carry out data analytics across and between all risk types.

These central libraries / taxonomies should aggregate up to a consistent set of Board-level risks that are used for:

- a. Board, Committee, Executive and all Risk Reporting.
- b. the setting and articulation of Risk Appetite.

¹ ISO 31000:2018 Risk Management Principles and Guidelines

- c. the core of the ERM system against which all risks across the enterprise are linked.
- all risk processes (refer to section 5) should be linked to these central libraries / taxonomies. This provides the ability to aggregate all risk information known about that risk category to be able to deliver a timely, dynamic, integrated risk profile (refer to section 8).
- use one Enterprise Risk Management solution that delivers on the above capabilities.

This is the basis of true Enterprise Risk Management. Once implemented, it solves the majority, if not all of the problems highlighted in section 2. In simple terms, ERM provides you with:

- a greater level of consistency in managing risk, and as a result, a greater level of understanding and resulting engagement from your staff. Everyone is a risk manager and ERM must engage as many staff across the enterprise as possible.
- the ability to manage risk much more effectively through better risk information in terms of coverage, timeliness, insights and understandability.
- a much lower cost in terms of investment of time and funds.

Warning!

Change management is critical in achieving ERM success. Staff who are risk specific specialists and have been doing risk management the same for many years will often be resistant to change.

To them, it's not broken, so why fix it? They have their risk-specific system solution that works for them and they don't wish to change. We have to demonstrate, that although it may not be "broken" for that specific risk in your business unit, it is "broken" for the enterprise as a whole.

4. The ERM ecosystem - How does it all fit together?

A strong ERM framework is built on fundamental principles. At Protecht, we call these principles the ERM ecosystem.

The key principles are:

- everything starts with Objectives. “Risk is the effect of uncertainty on objectives.”²
- risk management must link back to these objectives. This is achieved by linking the risks being managed to the related critical processes and projects, which in turn should be linked to the business and strategic objectives.

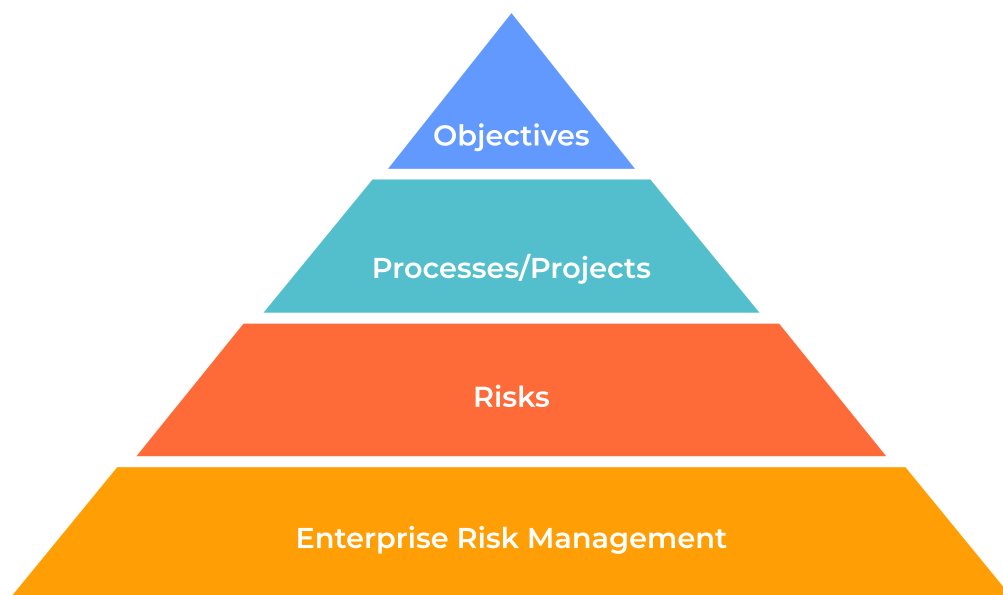


Fig 1. Linking between Enterprise Risk Management and Objectives

- the key risks of the enterprise must be identified and used as the basis of the central risk libraries to catalogue and link risks. These risk categories should be used consistently across the whole ERM framework.

² ISO 31000:2018 Risk Management Principles and Guidelines

- a robust Enterprise Risk Management Framework (ERMF) should be defined and used as the basis of all risk management across the enterprise. This should cover Governance, Processes and Systems, People and Culture, Escalation / Reporting / Response and Continuous Improvement.
- ERM Processes and Systems should be:
 - » comprehensive and cover all aspects of a risk's lifecycle.
 - » as far as possible, cover all risk and compliance related processes of the enterprise.
 - » be integrated, with the central risk libraries and with each other.
 - » be consistent and common yet reflect the nuances of each risk type.
 - » be flexible and tailorable so that:
 - the processes can grow with the organization.
 - users can tailor the system capabilities and experience to their specific needs while maintaining the integrity of the ERM principles.
 - » provide the Enterprise View of Risk using one reporting platform.

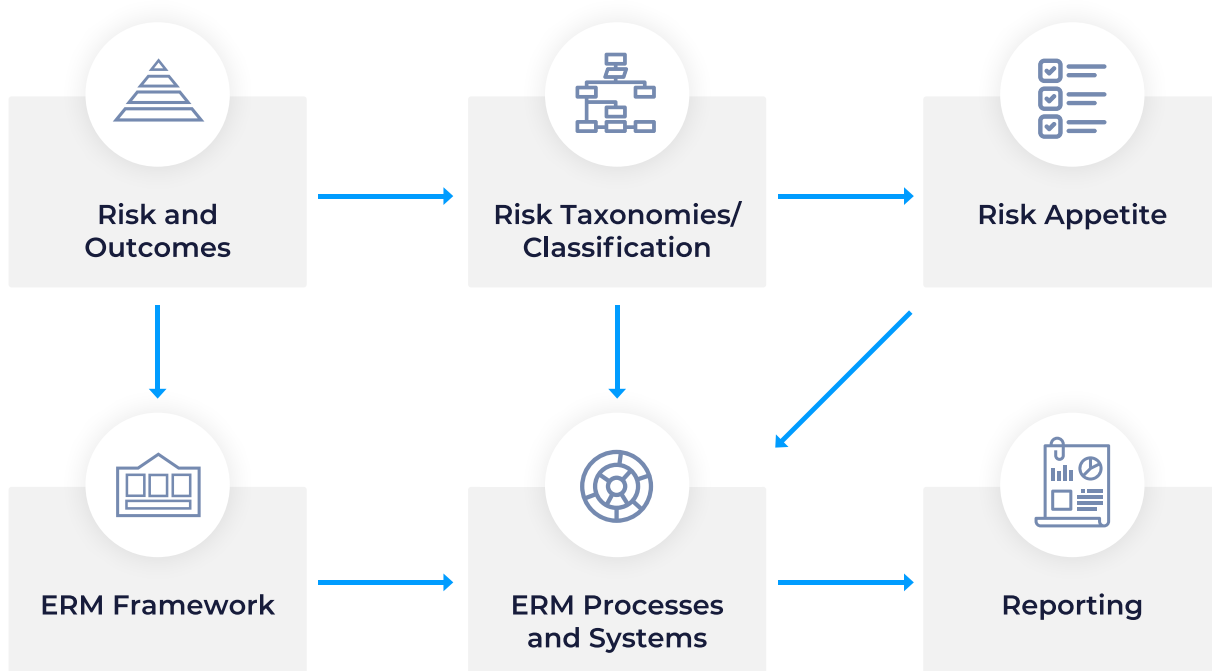


Fig 2. ERM Ecosystem

5. The key elements of an ERM Framework

ERM requires an overarching framework, the Enterprise Risk Management Framework (ERMF). This framework should align to, and incorporate, the relevant risk management standards that your enterprise aligns to - whether that be ISO 31000, COSO or other relevant standards.

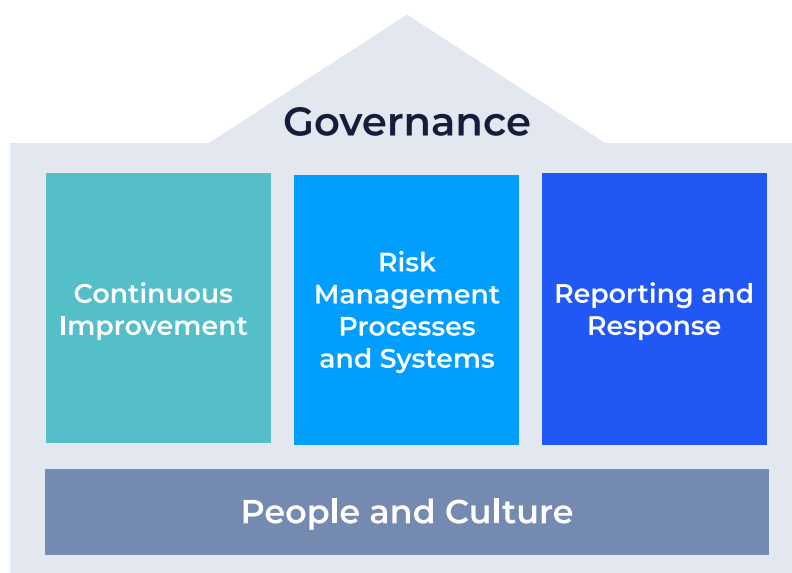
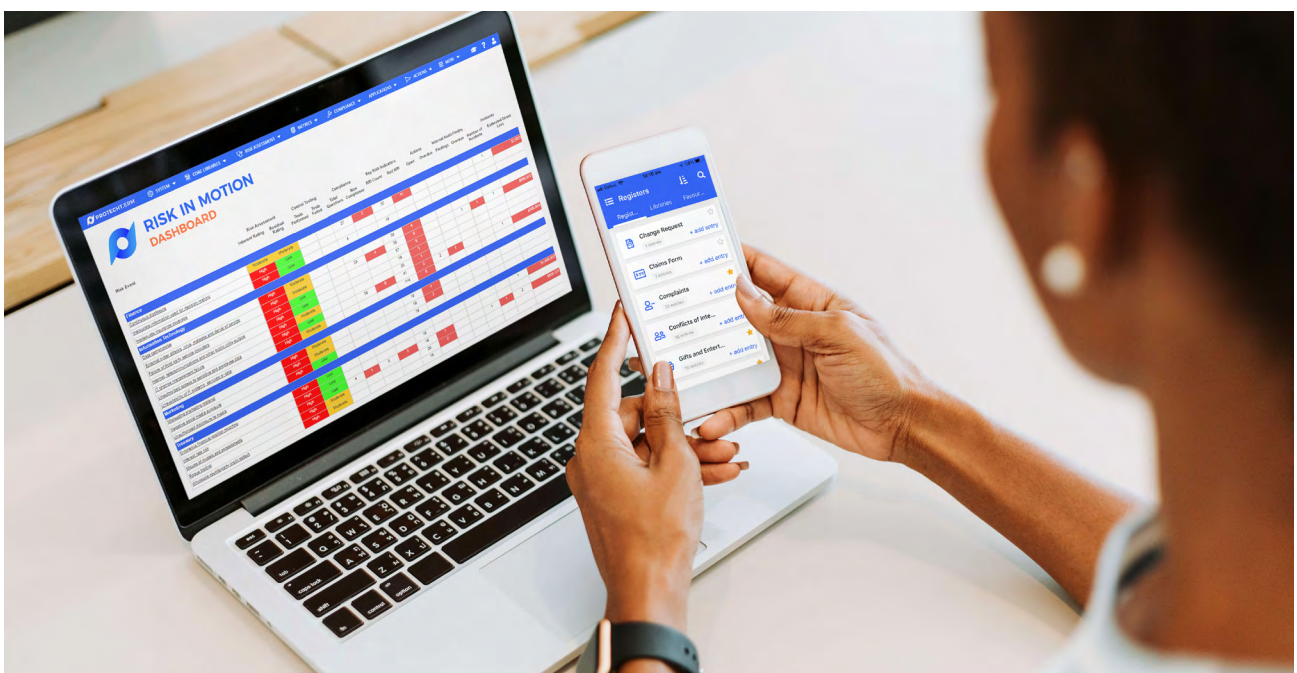


Fig 3. Enterprise Risk Management Framework – The “House”

The good practice ERM framework (“The House”) we use at Protecht contains 5 key components.

1. **The Roof – Governance.** This covers the mechanisms and structures that provide overall governance of ERM, including:
 - a. Roles, Responsibilities and Accountabilities of Board, Committees, Executives and Staff. This will include the “Three Lines” model, if adopted.
 - b. Risk Management Frameworks and Policies
 - c. Risk Appetite

2. **The Foundations - People and Culture.** This covers areas such as:
 - a. Organizational and Risk Culture
 - b. Conduct
 - c. Risk Capabilities, Competence and Knowledge
3. **The Rooms.** Risk Management Processes and Systems. This covers:
 - a. the core risk management processes, including but not limited to, Risk Assessment, Risk Metrics, Incident Management and Compliance.
 - b. risk specialisms such as Cyber, Workplace Health and Safety, ESG, Third Party Risk Management, Technology Risk Management, etc.
 - c. adjunct risk processes including Gifts and Entertainment, Contracts Management and Complaints Management.
4. **The Right Hand Wall – Reporting and Response.** This includes:
 - a. Escalations and workflows
 - b. Reporting and Analytics
 - c. Response
 - d. Decision Making
5. **The Left Hand Wall – Continuous Improvement.** This covers:
 - a. Issues and Actions Management
 - b. Root Cause Analysis
 - c. Risk Treatment
 - d. ERM maturity and development





6. The key elements of ERM Processes and Systems

The “engine room” of ERM is the ERM processes and systems.

The key to successful ERM is to have ERM processes and systems that:

- cover the full lifecycle of Risk from potential risk waiting to happen through to a risk incident having happened.
- cover the full range of enterprise risks, from Cyber, through Safety, to Third Party risk and everything else in between.
- are integrated with each other and with a central library / taxonomy of risks and controls.
- enable tailoring of process and content dependent on the specific risk type being managed. This may require additional sub processes, such as software license management and / or specific content and language.

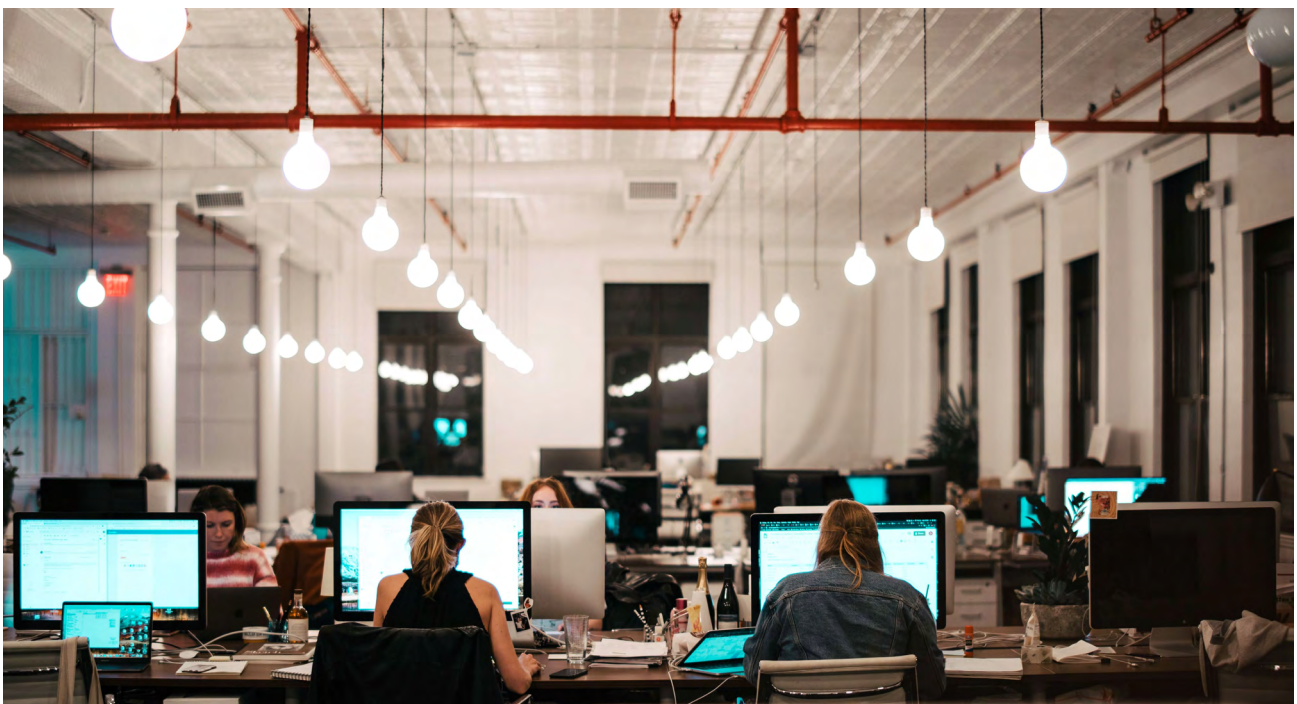




Fig 4. ERM Processes and Systems

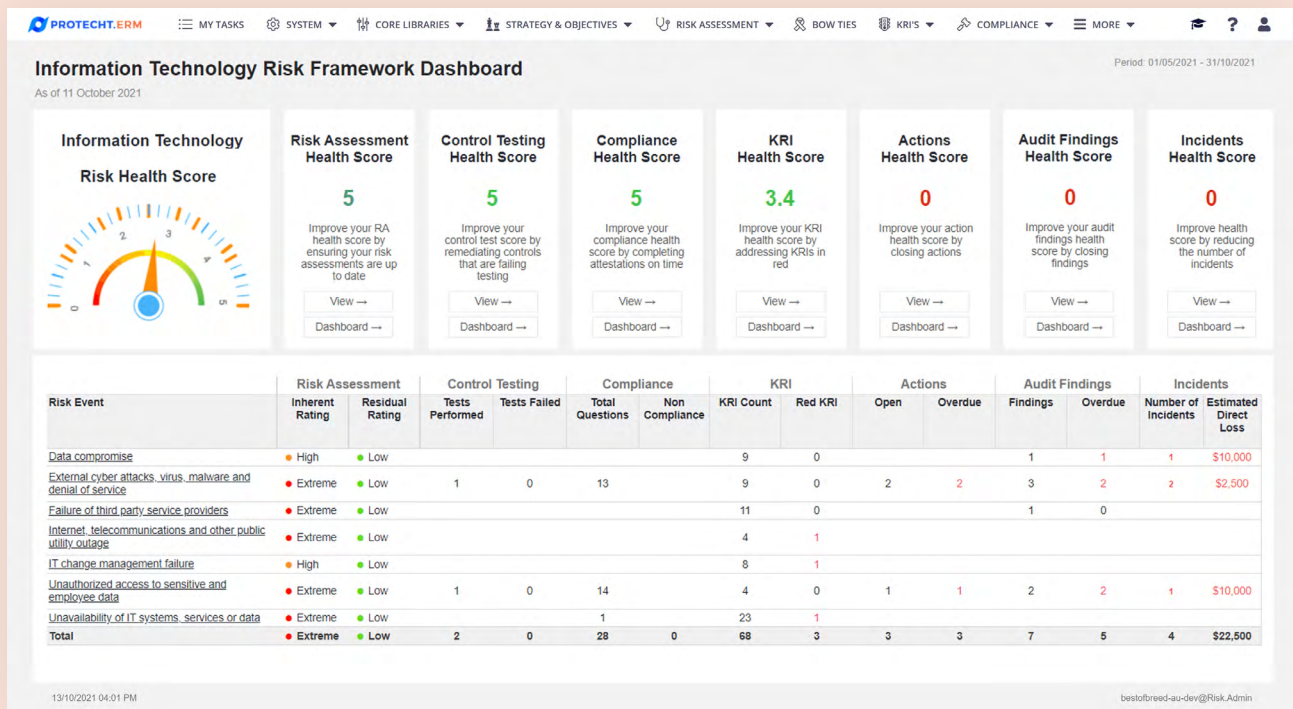
At the centre of true ERM are the central libraries / taxonomies. These allow linkage of all data to specific risks, risk components and controls. The key central libraries required are:

- Risk Causes
- Risk Events
- Risk Impacts
- Controls

The core ERM processes that need to be in place include:

- Risk Assessment
- Controls Assurance
- Risk Metrics
- Incident Management
- Issues and Actions Management
- Compliance
- Internal Audit

How we bring this information together is key – an example is provided below where core processes are linked to produce an overall ERM health score for the business unit. We can see an integrated view of the ERM framework information, allowing this business unit owner to focus on remediating overdue actions and audit findings to improve their ERM health score.



Example of a Business Unit ERM Health Score Card Dashboard

A risk-specific view should then be created for each material risk type such as ISMS, Fraud and Third Party. This creates a tailored experience for the risk management specialist yet uses the same ERM information and system. This ensures engagement from the risk specialist as well as serving the requirements of ERM to be able to aggregate and report all enterprise risks in a consistent manner.

For example, Environmental, Safety and Health (ESH) could have their own risk profile that connects different components such as hazards and inspections.



Risk Event	Risk Assessment		Internal Audit		Safety Observations		Safety Hazards		Safety Incidents					
	Inherent Rating	Residual Rating	Audit Findings	Overdue Findings	Observations	Open Actions	Total	Open	Near Miss	Incidents	First Aid Injuries	Medical Treatment Injuries	Lost Time Injuries	Open Action
Environment Health and Safety														
Slips, Trips or Fall of a Person	High	Moderate			9	4	6	3	0	4	1	1	1	
Heat, Electricity and Other Environmental	High	Moderate	1	1	1	0	1	1	0	3	1	0	0	
Mental Stress	High	Moderate					2	2	0	3	1	2	0	1
Body Stressing	High	Low	2	2	6	2	6	3	0	3	1	2	0	
Chemicals and Other Substances	High	Low			1	0	1	0	0	1	1	0	0	
Hitting Objects With Part of the Body	High	Low			4	0	3	1	0	1	1	0	0	
Biological Factors	Moderate	Low					1	1	0	4	2	2	0	1
Being Hit by Moving Objects	Moderate	Low					1	1	1	2	0	1	1	
Sound and Pressure	Moderate	Low					1	0	0	1	0	1	0	

Example of a Dynamic Environmental, Safety and Health (ESH) Risk Report

Reporting and Analytics are then applied to the complete data pool of ERM information using the same reporting capability so that a complete, tailored picture can be provided to all levels of the organization. A key to ERM is:

“one source of truth, reported and used multiple times”



7. Building an ERM framework that can grow

ERM and risk management more generally has been developing and maturing rapidly over the last 20 or so years. This maturity development has come from:

- development in Risk Thinking and Risk Methodologies.
- development in technology capability.
- rapidly changing risk landscape.
- increasing focus from regulators.
- increased adoption by risk management across every enterprise.

This development and increased maturity are not slowing down any time soon. It is therefore critical that your ERM framework and related systems and processes are able to continually grow and mature. Your approach to ERM must be able to quickly adapt, with changes made in an agile, efficient manner. This requires ERM technology that can grow with you and be easily modified and developed by the users.

“ERM is a journey, and we are only part way there”

The keys to remaining current and relevant are:

- be open and willing to develop your risk capability for the foreseeable future.
- partner risk specialists, advisors and software providers who are flexible, can grow with you and have a strong vision of the future.
- select ERM software that truly delivers on the key elements of ERM and is able to be tailored, modified and developed by the user themselves rather than software developers.
- develop a strategic plan for the risk management function based on a “blueprint” of where you want ERM to be in your organization in 1, 3, 5 years and measure progress to that point.
- manage change effectively and efficiently by bringing all of your staff along on the risk management development journey.



8. The outputs, uses and value proposition of ERM

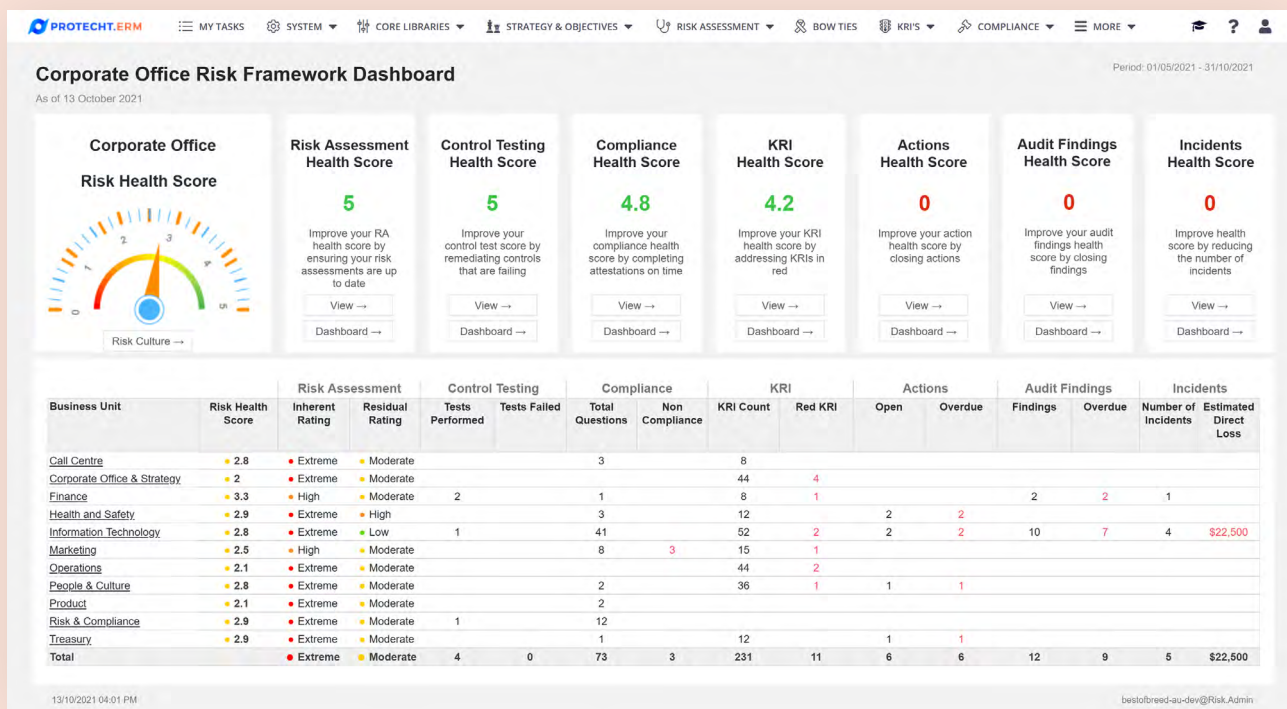
A key characteristic of strong ERM is that it is outcome and not process focused. The processes of ERM are a means to an end. The value of ERM is only achieved from the outputs it can produce and how those outputs are used to add value.

The ERM processes enable an enterprise to collect a wide range of risk related information. It is what we do with that information that creates value. Value is created from risk information through:

1. providing assurance – providing confidence that all is OK and highlighting issues / red flags / early warnings.
2. prompting decisions to be made.
3. providing risk information that is useful to assist in better decision making.
4. providing important risk insights that were not previously known / new information.
5. providing useful risk information earlier so risk can be managed in a proactive rather than reactive way.
6. providing transparency in an objective way so everyone knows what's really going on.

It's in the reporting and analytics where true ERM comes into its own. Given that ERM should capture all risk-related information as it arises, and that information is integrated and able to be linked, the reporting and analytics can be dynamic and integrated.

The following is an example of ERM integrated, dynamic risk profiling – where individual business units that have their own risk profiles are aggregated to produce a truly enterprise risk management health score. Readers can clearly see that the framework areas that need focus are issues, actions and incidents. We want our ERM output to guide us quickly and efficiently to problem areas.



Example of Integrated Dynamic Risk Reporting - Protecht's Risk in Motion™ Reporting

This approach to reporting is based on:

- all risk information (Risk Assessment, Risk indicators, Controls Testing, etc.) from each of the ERM processes to be linked to the same Risk Type.
- updating of the reporting instantaneously so that the report is always based on the most recent available information.
- ability to drill down into any component to analyse the detail behind the information.

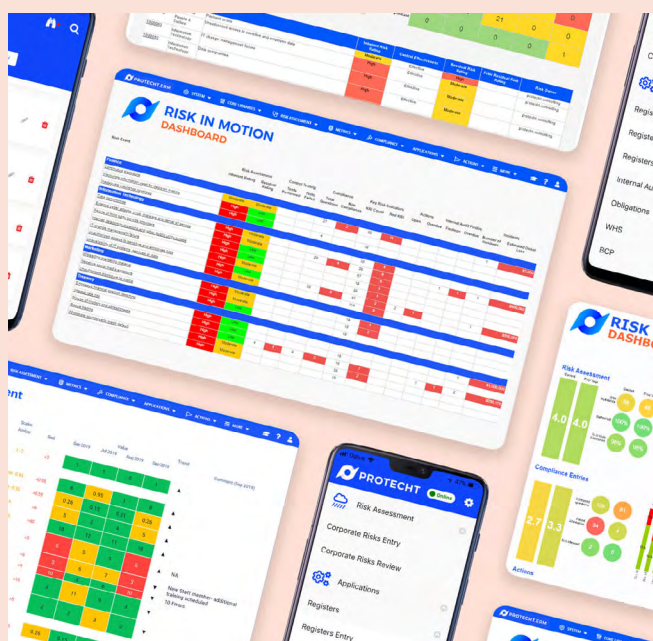
9. Your next steps - making it happen

“Take time to deliberate, but when the time for action comes, stop thinking and go in.”

NAPOLEON BONAPARTE

If the siloed, inefficient, ineffective, duplicated, complicated and costly risk management resonates with you, deliberate for a while and then “go in”.

“Go in” to true ERM. That said, you need to ensure you go to “war” with partners who will deliver for you and understand the difference between effective and ineffective ERM. To help you go to war, Protecht will be delivering a series of ebooks covering the key ERM processes, such as Risk and Controls Self Assessment, Risk Metrics, Incident Management, and Compliance Management. Watch this space!



**Dynamically manage
all your risks in a single
platform**

Protecht.ERM is fully integrated across all functions. Data capture, assessment, automated workflow and sophisticated reporting can all be done in the same flexible system. Get in touch with us to learn more.

About the Writer



DAVID TATTAM

CHIEF RESEARCH AND CONTENT OFFICER

David Tattam is the Chief Research and Content Officer and co-founder of the Protecht Group. David's vision is to redefine the way the world thinks about risk and to pioneer the development of risk management to its rightful place as a key driver of value creation in each of Protecht's clients. David is the driving force behind Protecht's risk thinking, pushing risk management to the frontiers of what is possible. He is also focused on driving the uplift of people risk capability through training and content.

David is passionate about risk and risk management and in reaping the value that risk and good risk management can create for any organization willing to embrace it. He is particularly passionate about risk management research and is prolific in creating a wide range of content delivered in blogs, eBooks, webinars and training courses. He has developed Protecht's comprehensive suite of risk management training courses and has, and continues, to train many thousands of risk practitioners across the globe. David also manages Protecht's consulting business offering a range of risk consulting capabilities from Risk Management Framework to Risk Appetite Statement development.

He is also the author of "A Short Guide to Operational Risk".

Prior to co-founding Protecht, David was the Chief Risk Officer and Head of Operations for the Australian operations of two global banks. He started his career as a Chartered Accountant and Auditor with Grant Thornton and PwC. David is an Associate of the Institute of Chartered Accountants in Australia and New Zealand and a Senior Fellow of the Financial Services Institute of Australia.

About Protecht

Redefining the way the world thinks about risk.

While others fear risk, we embrace it. For over 20 years, we have redefined the way people think about risk management with the most complete, cutting-edge and cost-effective solutions.

Protecht helps companies increase performance and achieve strategic objectives through better understanding, monitoring and management of risk. We provide the complete risk solution, comprised of world class enterprise risk management (Protecht.ERM), compliance, training and advisory services to large government organizations, key regulators and businesses of all sizes across the world.

Dynamically manage all your risks in a single platform: Risks, Compliance, Health and Safety, Internal Audit, Incidents, KRIs, BCP, and more.

We're with our clients for their full risk journey. Let's transform the way you understand and manage your risk to create exciting opportunities for growth.



AUSTRALIA & ASIA PACIFIC

+61 2 8005 1265
Level 8
299 Elizabeth St.
Sydney NSW 2000
Australia

EUROPE, THE MIDDLE EAST & AFRICA

+44 (0) 203 978 1360
77 New Cavendish Street
The Harley Building
London W1W 6XB
United Kingdom

NORTH AMERICA

+1 (833) 328 5471
312 Arizona Ave #334
Santa Monica
California 90401
United States

Visit our website:
protechtgroup.com

Email us:
info@protechtgroup.com